

PRODUCT REQUIREMENTS DOCUMENT (PRD)

Product Name: Premium Sneaker E-Commerce Platform

Architecture: Next.js (Frontend) + Express.js (Backend) + PostgreSQL (Prisma ORM)

API Base Path: /api/*

1. PRODUCT OVERVIEW

1.1 Purpose

The system is a full-stack e-commerce platform for selling premium sneakers. It enables:

- Public users to browse, search, filter, and purchase sneakers.
- Administrators to manage products, orders, brands, categories, and banners.
- Secure API communication using JWT-based authentication for protected routes.
- Performance, SEO, and operational monitoring via health, readiness, sitemap, and performance endpoints.

1.2 Objectives

- Provide a responsive, accessible storefront.
 - Enable full CRUD administration of catalog data.
 - Allow checkout with order persistence.
 - Ensure security, rate limiting, logging, and operational readiness.
-

2. SYSTEM SCOPE

2.1 In Scope

- Product browsing and filtering
- Product detail retrieval
- Shopping cart (client-side persistence)
- Checkout and order creation
- Admin authentication
- Admin product, order, brand, category, banner management
- File upload via signed S3 key

- Health and readiness checks
- Rate limiting and logging
- Static file serving
- Sitemap generation

2.2 Out of Scope

- Customer user accounts (non-admin authentication)
- Online payment gateway integration (external processor)
- Inventory reservation system
- Multi-currency support
- Refund management

3. FUNCTIONAL REQUIREMENTS

Each requirement is written in testable format.

FR-01: Product Listing

Description: System must return sneakers with optional filters.

Endpoint: GET /api/sneakers

Inputs (Query Params):

- category
- brand
- search

Behavior:

- Returns JSON array of sneaker objects.
- Filters applied at database query level.
- Returns HTTP 500 on database failure.

Acceptance Criteria:

- Response status 200 for valid request.
- Filtered results reflect query parameters.
- Invalid DB state returns 500.

FR-02: Product Detail

Endpoint: `GET /api/sneakers/:slug`

Behavior:

- Returns sneaker matching slug.
- Returns 404 if not found.

Acceptance Criteria:

- Valid slug returns 200 with product data.
 - Non-existent slug returns 404.
-

FR-03: Shopping Cart

Location: Frontend (client-side)

Behavior:

- Items stored in `localStorage`.
- Totals calculated client-side.
- Quantity must be greater than 0.

Acceptance Criteria:

- Cart persists after page reload.
 - Invalid quantity rejected in UI.
 - Cart total matches sum of items.
-

FR-04: Checkout & Order Creation

Endpoint: `POST /api/orders`

Inputs:

- Billing details
- Delivery method
- Payment method

- Cart items

Behavior:

- Validates required fields.
- Creates Order and OrderItem records.
- Returns order ID.

Acceptance Criteria:

- Valid request returns 200 and order ID.
 - Missing required fields return 400.
 - Server errors return 500.
-

FR-05: Admin Authentication

Endpoint: `POST /api/auth/login`

Behavior:

- Validates email format and password.
- Compares password via bcrypt.
- Verifies `isAdmin`.
- Returns JWT (8h expiry).

Acceptance Criteria:

- Valid credentials return 200 + JWT.
 - Invalid credentials return 401.
 - Non-admin user returns 403.
-

FR-06: Admin Stats Dashboard

Endpoint: `GET /api/admin/stats`

Authorization: Bearer JWT required

Behavior:

- Returns counts: products, orders, revenue, pending orders.

Acceptance Criteria:

- Valid admin token returns 200.
 - Missing/invalid token returns 401.
-

FR-07: Admin Product Management

Endpoints:

- GET /api/admin/products
- POST /api/admin/products
- PUT /api/admin/products/:id
- DELETE /api/admin/products/:id

Behavior:

- Full CRUD via Prisma.
- Protected by JWT + isAdmin.

Acceptance Criteria:

- Admin can create/update/delete product.
 - Non-admin receives 403.
-

FR-08: Admin Order Management

Endpoints:

- GET /api/admin/orders
- PUT /api/orders/:id

Behavior:

- Admin can filter orders.
- Admin can update status.

Acceptance Criteria:

- Invalid order ID returns 404.
- Invalid status returns 400.

FR-09: Category, Brand, Banner Management

CRUD endpoints exist for each entity.

Acceptance Criteria:

- Entities persist correctly.
- Protected by admin authentication.

FR-10: File Upload

Endpoint: `POST /api/s3/upload-key`

Behavior:

- Generates signed upload credentials.
- Uses AWS SDK.

Acceptance Criteria:

- Valid request returns signed data.
- Failure returns 500.

FR-11: Health & Readiness

Endpoints:

- `/api/health`
- `/ready`

Behavior:

- Health returns uptime JSON.
 - Ready verifies DB connection.
 - DB failure returns 503.
-

FR-12: Rate Limiting

Behavior:

- 100 requests per 15 minutes per IP.
 - Exceeding limit returns 429.
-

4. NON-FUNCTIONAL REQUIREMENTS

4.1 Performance

- Gzip compression enabled.
- Static files cached for 1 day.
- Target Lighthouse score > 85.

4.2 Security

- JWT signed using HS256.
- Token expiry: 8 hours.
- CORS origin restriction enforced.
- CSP, HSTS, XSS protection headers applied.
- Body size limit: 10MB.
- Rate limiting enforced globally.

4.3 Reliability

- Graceful shutdown on SIGINT/SIGTERM.
 - Readiness endpoint verifies DB availability.
 - Errors logged with request context.
-

5. DATA MODEL

Entities

User

- id
- email

- password
- name
- isAdmin (boolean)

Sneaker

- id
- slug (unique)
- name
- description
- price
- discount
- brandId
- categoryId
- images

Order

- id
- status
- total
- deliveryMethod
- paymentMethod
- billing details
- createdAt

OrderItem

- id
- orderId
- sneakerId
- quantity
- price

Brand

- id
- name
- slug

Category

- id
- name
- slug

Banner

- id
 - imageUrl
 - linkUrl
 - altText
-

6. BUSINESS RULES

- Only users with `isAdmin = true` may access admin endpoints.
 - Product slugs must be unique.
 - Order total derived from sum of items + shipping.
 - Payment methods limited to:
 - M-Pesa
 - Cash on Delivery
 - Delivery methods limited to:
 - Same-day
 - Next-day
 - Pickup
 - JWT expiration enforced (8 hours).
-

7. WORKFLOW DEFINITIONS

7.1 Customer Purchase Flow

1. Browse products.
2. View product detail.
3. Add to cart.
4. Proceed to checkout.
5. Submit order.
6. Receive confirmation.

7.2 Admin Management Flow

1. Login.
2. Receive JWT.
3. Access dashboard.
4. Manage products/orders/catalog data.

8. ERROR HANDLING MATRIX

Scenario	Expected Response
Invalid login	401
Non-admin access	403
Missing token	401
DB failure	500
Resource not found	404
Rate limit exceeded	429
DB unavailable (ready)	503

9. DEPLOYMENT & OPERATIONS

- Express server entry: `src/server.js`
- Prisma DB client initialized at startup.
- Static files served via `/uploads`.
- Environment variables required for:
 - DB connection
 - JWT secret
 - AWS credentials
 - CORS origins